PT WORKBENCH

פלג אלבז | פרויקט גמר באבטחת מידע | גרסה 1.0

מבדיקה בודדת לתהליך חקירה מסודר

הפרויקט הוא סביבת עבודה לבדיקות אבטחה מורשות: מגדירים מה מותר לבדוק, מבצעים פעולות מדודות, שומרים תצפיות ומרכזים אותן לדוח. המטרה היא להפוך ניסויים מפוזרים לתהליך שאפשר להסביר, לבקר ולהציג. לכל הרצה יש יעד, סוג פעולה, תוצאה והקשר להרשאה שניתנה.

מה בניתי עד היום

התחלתי בסביבת Kali Linux, עם VS Code ו-Claude Code לפיתוח מדורג. בניתי אפליקציית Python ו-Flask, שילוב ראשוני של Nmap ו-WhatWeb, מסד SQLite לשמירת סריקות וממצאים ואתר מעבדה מקומי. בהמשך הוחלף מסלול ההרצה הישן במנגנון שמחייב הגדרת תחום בדיקה ומדיניות לפני ביצוע פעולה.

מנוע Scope בודק דומיינים, כתובות IP, טווחי CIDR וכתובות Web. החרגות גוברות על הרשאות. מנוע Policy בודק שההתקשרות מאושרת ושהפעולה הותרה. מגבלת הקצב נאכפת בחלון מתגלגל של דקה, עם שמירת מקום במסד הנתונים לפני פתיחת חיבור. גם ניסיונות שנכשלו לאחר שמירת מקום נכללים במכסה.

מה כוללת הגרסה הנוכחית

ממשק ניהול מעוצב עם כניסת מפעיל, יצירת התקשרויות ואישורן, ביטול הרשאה, היסטוריית הרצות, סקירת תצפיות ודוחות. הפעולות הפעילות כוללות בקשת HTTP מסוג GET, HEAD או OPTIONS, בירור DNS, בדיקת תעודת TLS וחיבור למספר קטן של פורטי TCP שנבחרו מראש.

לצד הפעולות קיימים ניתוחים ללא תעבורת רשת: כותרות אבטחה, מאפייני cookies, טפסים, קישורים וסימנים לשגיאות. ניתן לייבא קובצי Burp ו-Nmap וליצור וריאציות בקשה לעיון ידני ב-Repeater. הייבוא והתכנון אינם שולחים בקשות בעצמם. בדיקות ניתוח עצמאיות יכולות לפעול במקביל על אותו מידע שנלכד.

הערך של הפרויקט

החיבור בין הרשאה, ביצוע, תיעוד וביקורת ידנית הוא לב המערכת. כל תצפית מתחילה כ״טרם נבדקה״. המפעיל מאשר או דוחה אותה ומוסיף הסבר; היסטוריית השינויים נשמרת. ניתן להפיק דוח להדפסה או לשמירה כ-PDF, וכן לייצא נתונים בפורמט JSON.

תכנית להצגת הפרויקט - כ-7 דקות

1. פתיחה: מציגים את הבעיה שהכלי פותר ואת לוח הבקרה. מסבירים שהבדיקות נעשות במסגרת הרשאה מוגדרת ושממצאים עוברים ביקורת אנושית.

2. הגדרת מעבדה: מציגים התקשרות מאושרת לאתר המקומי, פעולה מותרת ומכסה של 10 בקשות בדקה. מראים תחילה תצוגה מקדימה של החלטת הרשאה, בלי לשלוח בקשה.

3. בדיקה חיה: שולחים GET אחד לאתר המעבדה ומציגים את התוצאה והתצפיות. מציגים גם דחיית יעד שאינו בסקופ. את בדיקת העומס וההרצות המקבילות מדגימים באמצעות בדיקות אוטומטיות מבוקרות.

4. חקירה וסיכום: פותחים תצפית, מוסיפים הערת ביקורת ומחליטים אם לאשר או לדחות. מציגים את היסטוריית השינוי, מייצאים דוח ומסבירים מה נבדק ומה עדיין אינו ידוע.

סביבת ההדגמה והמשך הדרך

להדגמה ראשונה כדאי להשתמש באתר המעבדה המצורף. להמשך מוצע OWASP Juice Shop בהתקנה מקומית: זהו יישום שנבנה לתרגול ולבחינת כלי אבטחה. חלופות הן WebGoat ומעבדות PortSwigger Academy. ההמלצה אינה הבטחה שהכלי יפתור את אתגרי המעבדות; התוצאה תלויה בסוג הבדיקה ובאימות ידני.

בדיקה מול ״ניאון״ עדיין לא בוצעה. לפני הדגמה חיצונית יש לזהות את כתובת היעד המדויקת ואת תחום ההרשאה. הופעת שם של אתר בפרויקט אינה מעידה שהוא נבדק או שנמצאה בו חולשה.

מה הוכח ומה הגבולות

הגרסה עברה 113 בדיקות אוטומטיות על מסדי נתונים זמניים ובחיבורי רשת מדומים, לרבות הרשאות, מכסות, ייבוא וסקירה. בנוסף עברה בדיקת HTTP מול שרת מקומי זמני: GET ו-HEAD הצליחו, הפניה לא נעקבה ויעד אסור נחסם. בדיקת ההתקנה ב-Kali והתצוגה בדפדפן של המשתמש היא שלב הקבלה הבא. הקוד והמסמך אינם טוענים שנערכה בדיקת חדירה מלאה באתר חיצוני.

המערכת משתמשת בבדיקות מוגדרות מראש; אין בה סוכן AI אוטונומי לניצול חולשות. כותרת חסרה, פורט פתוח או סימן לשגיאה הם בסיס לבדיקה נוספת. אין קביעה אוטומטית של SQL Injection, XSS או פגיעה עסקית. גופי תגובות וסודות אינם נשמרים אוטומטית, אך על המפעיל להימנע מהכנסת מידע רגיש להערות חופשיות.

Official lab references (checked 25 Sep 2026):
owasp.org/projects/juice-shop | owasp.org/projects/webgoat
portswigger.net/web-security